TECHNICAL DETAIL

Title	Stored Cross-Site Scripting (XSS) via Malicious SVG File Upload targeting Administrator
Reporter	Daffa Rahadya Atmawiguna (rahadya.daffaa@gmail.com)
Date	2025-12-28
Affected Asset	https://bertani.my.id/admin/files
Severity	**Medium**
CVSS Score	5.4 CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:L/I:L/A:N
Proof of Concepts	Please see Steps to Reproduce section

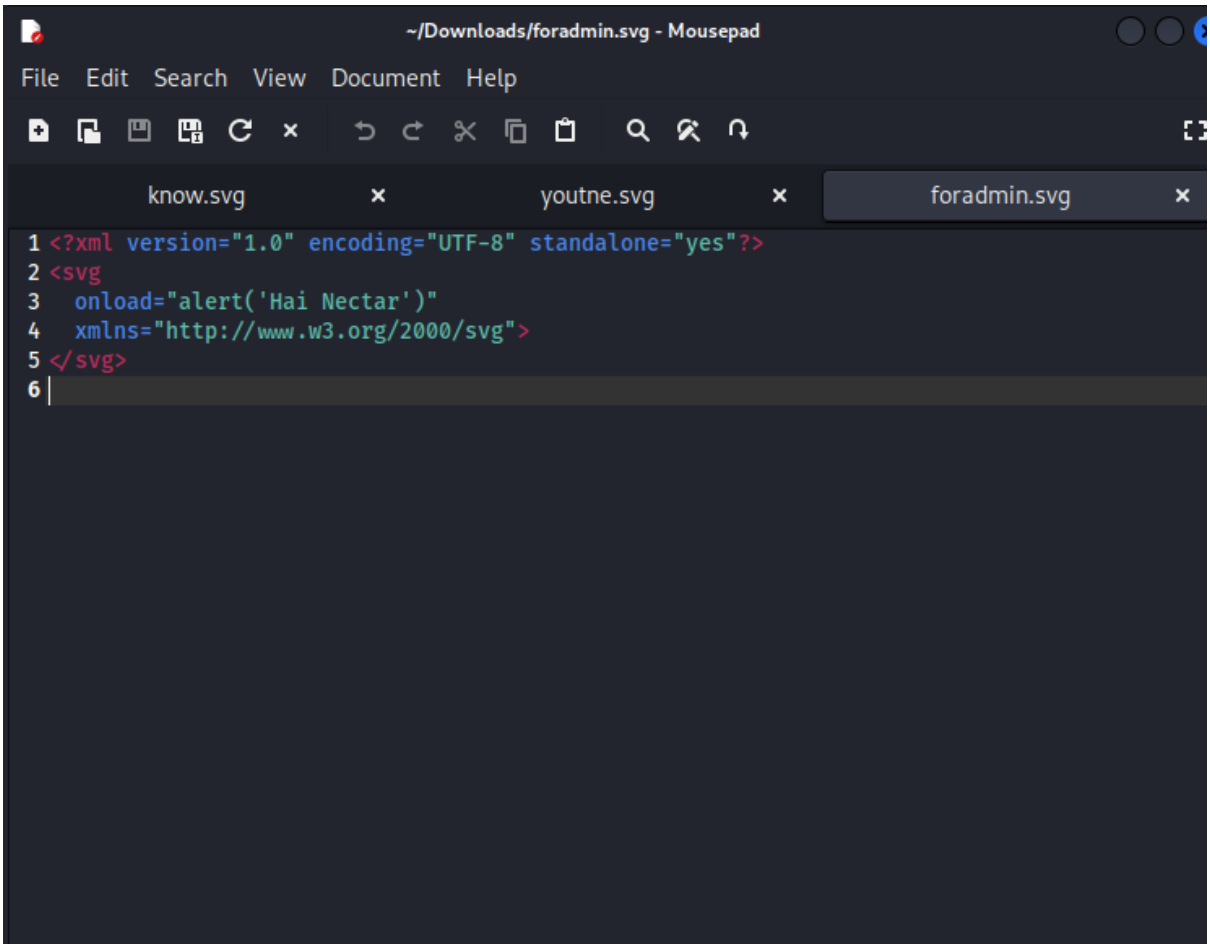
SUMMARY

Ditemukan kerentanan **Stored Cross-Site Scripting (XSS)** pada fitur unggah berkas di platform Bertani. Penyerang dapat mengunggah file gambar berformat SVG yang telah disisipi kode JavaScript berbahaya. Karena Administrator memiliki wewenang untuk memeriksa atau meninjau berkas yang diunggah pengguna melalui panel Manage Files, skrip tersebut akan tereksekusi secara otomatis di browser Administrator saat mereka menekan tautan "See attachment"

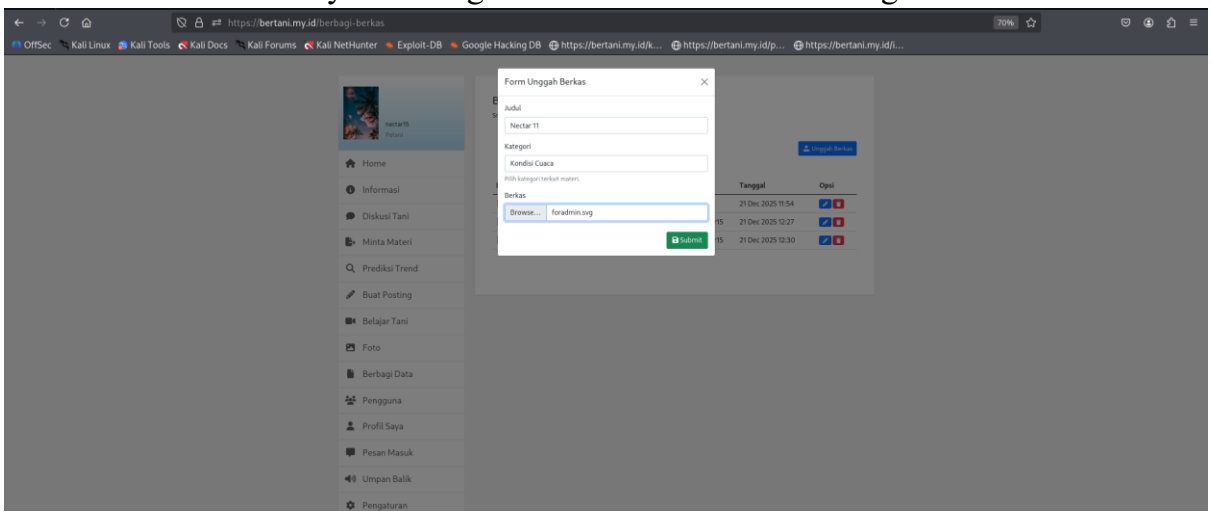
STEPS TO REPRODUCE

1. Login ke Akun Anda sebagai user di URL https://bertani.my.id/login

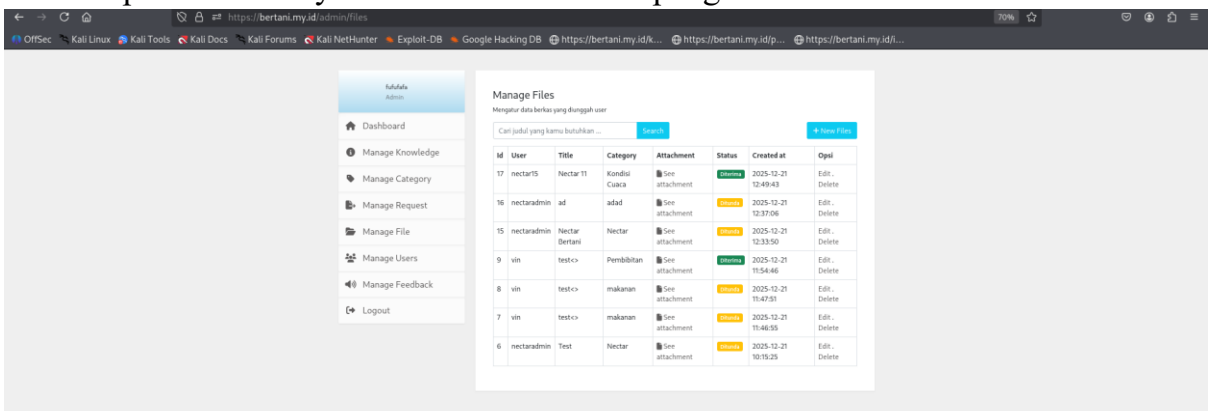
2. Buat file svg yang berisi



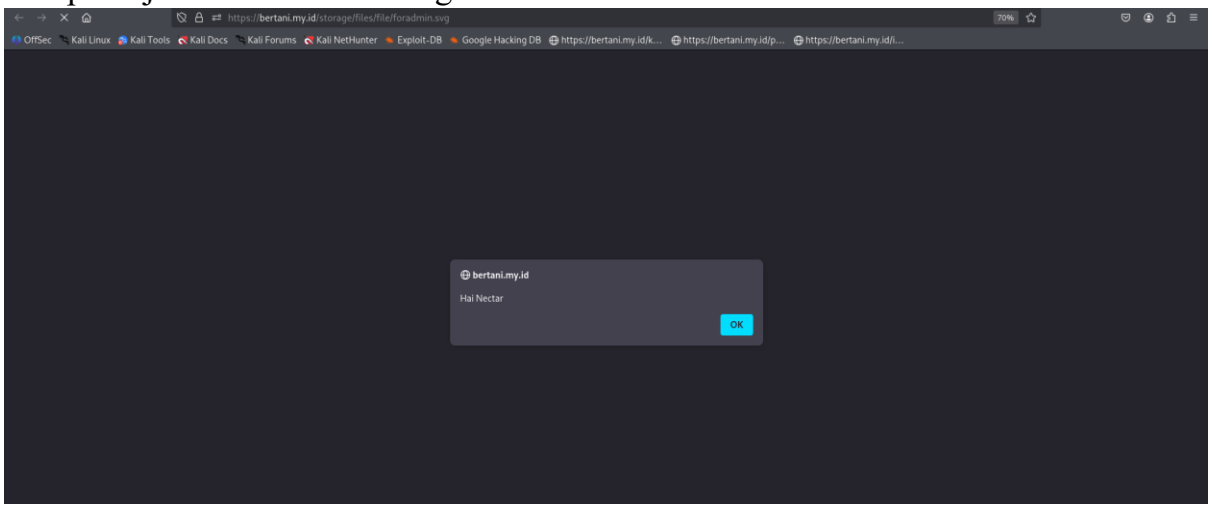
3. Masuk ke url bertani.my.id/berbagi-berkas dan masukan file svg tersebut



4. Maka saat admin menekan see attachment yang sudah kita submit tadi yang ada di url https://bertani.my.id/admin/files akan terpengaruh



5. Tampilan jika admin menekan gambar



EXPECTED RESULT

Sistem seharusnya melakukan proses sanitasi dan pembersihan secara menyeluruh terhadap setiap file SVG yang diunggah oleh pengguna untuk menghapus elemen atau atribut berbahaya seperti onload. Saat Administrator memeriksa lampiran berkas, file tersebut tidak boleh mengeksekusi skrip apa pun dan hanya ditampilkan sebagai gambar statis atau diunduh secara aman tanpa render otomatis oleh browser

ACTUAL RESULT

Aplikasi menerima dan menyimpan file SVG berbahaya tanpa adanya validasi konten yang ketat. Hal ini menyebabkan browser Administrator mengeksekusi kode JavaScript di dalam file tersebut saat diakses melalui URL penyimpanan /storage/files/file/foradmin.svg. Penyerang berhasil memicu eksekusi skrip di sisi Administrator, yang membuktikan adanya celah untuk mencuri data sesi admin.

IMPACT

1. Admin Account Takeover: Penyerang dapat mencuri *session cookies* Administrator untuk mengambil alih akun dengan hak akses tinggi.
2. Privilege Escalation: Memungkinkan pengguna tingkat rendah untuk menyerang dan mendapatkan kontrol atas akun otoritas yang lebih tinggi yaitu admin.

RECOMMENDATION

Sanitasi File SVG: Gunakan library seperti DOMPurify di sisi server untuk membersihkan tag <script> dan atribut *event handler* sebelum file disimpan.

REFERENCES

1. **OWASP - Unrestricted File Upload:** https://owasp.org/www-community/vulnerabilities/Unrestricted_File_Upload
2. **PortSwigger - Stored XSS via SVG File:** https://portswigger.net/web-security/cross-site-scripting/stored